CyberDefenders

RESOLUCIÓN DE LABORATORIO

Lab: Insider (CyberDefenders)

Análisis forense de artefactos en imagen de disco Linux. Comprende la investigación de registros del sistema (logs) y el historial de Bash mediante FTK Imager para reconstruir acciones de usuarios e identificar amenazas internas (Insider Threats).

Sebastian David
Torres Reyes

Escenario:

Tras empezar a trabajar para 'TAAUSAI', Karen comenzó a realizar actividades ilegales dentro de la empresa. 'TAAUSAI' lo contrató como analista de SOC para iniciar una investigación sobre este caso.

Obtuvo una imagen de disco y descubrió que Karen usa Linux en su equipo. Analice la imagen de disco del ordenador de Karen y responda a las preguntas.

Herramientas utilizadas:

- FTK Imager

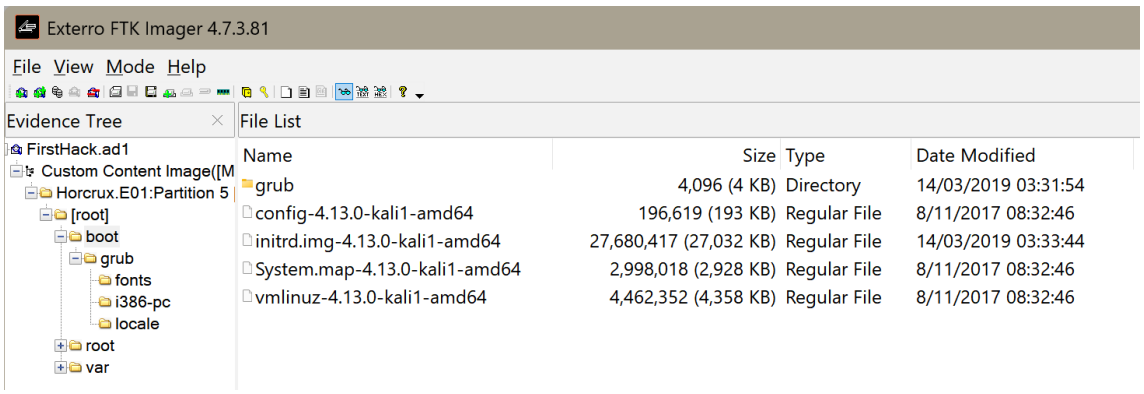
Resumen:

El incidente analizado revela una Amenaza Interna (Insider Threat) protagonizada por una empleada llamada Karen, quien utilizó una distribución de Kali Linux no autorizada para realizar actividades ilícitas dentro de la organización. A pesar de la escasa evasión forense, la investigación de los registros de Bash y autenticación demostró elevación de privilegios, el uso de herramientas de ingeniería inversa (Binwalk) y la descarga de utilidades para el volcado de credenciales (Mimikatz). El impacto final consistió en el uso de este equipo para atacar lateralmente a otros sistemas de la red mediante la ejecución de binarios sospechosos, todo ello motivado por lucro económico personal.

P1: ¿Qué distribución de Linux se está utilizando en esta máquina?

R: Kali

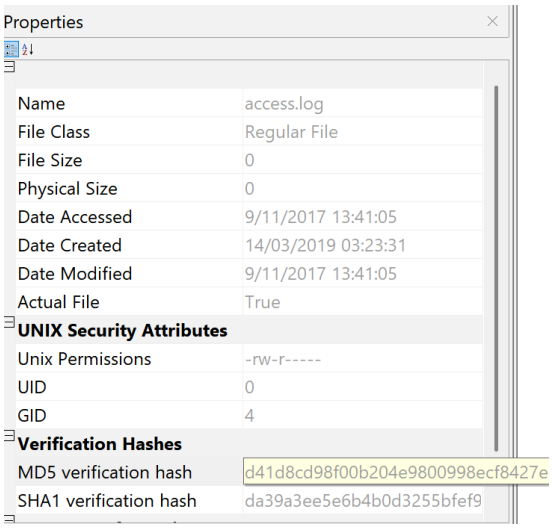
Para el análisis de la imagen lógica se utilizó la herramienta FTK Imager y se encontró en el directorio boot, directorio que contiene todo lo necesario para que el sistema operativo funcione, información sobre el sistema operativo, así como la distro de Linux que usó Karen, una distro con herramientas integradas dedicadas para el pentesting.



P2: ¿Cuál es el hash MD5 del archivo access.log de Apache?

R: d41d8cd98f00b204e9800998ecf8427e

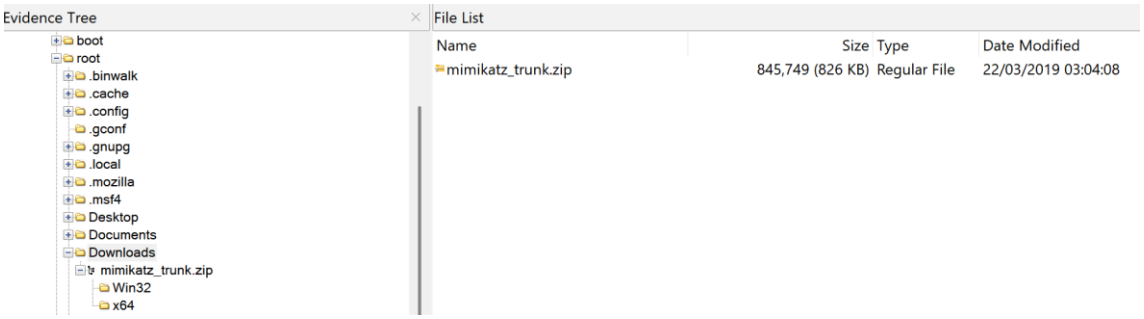
En las propiedades del archivo dadas por FTK Imager se pudo hallar el hash MD5 del archivo access.log. Cabe destacar que el hash d41d8cd98f00b204e9800998ecf8427e es el hash MD5 universalmente conocido para un archivo vacío (0 bytes).



P3: Se sospecha que se descargó una herramienta de volcado de credenciales. ¿Cómo se llama el archivo descargado?

R: mimikatz_trunk.zip

Se investigaron las descargas mostradas por la imagen lógica y se encontró que Karen descargó el archivo mimikatz_trunk.zip. Mimikatz es una de las herramientas más potentes y conocidas para el robo y extracción de credenciales de Windows.



P4: Se creó un archivo supersecreto. ¿Cuál es la ruta absoluta a este archivo?

R: /root/Desktop/SuperSecretFile.txt

En el archivo .bash_history se pudo visualizar el historial de los comandos ejecutados por Karen. El directorio del archivo supersecreto es /root/Desktop/SuperSecretFile.txt.

```
systemctl enable postgresql
systemctl start postgresql
msfconsole
msfdb init
msfconsole
shutdown now
touch snky snky > /root/Desktop/SuperSecretFile.txt
cat snky snky > /root/Desktop/SuperSecretFile.txt
msfconsole
clear
history
clear
```

P5: ¿Qué programa utilizó el archivo didyouthinkwedmakeiteasy.jpg durante su ejecución?

R: binwalk

En el historial de comandos se observó que Karen utilizó binwalk para abrir el archivo JPG. Esta herramienta es utilizada para analizar, realizar ingeniería inversa y extraer archivos de imágenes de firmware y binarios.

```
history > history.txt
binwalk didyouthinkwedmakeiteasy.jpg
clear
```

P6: ¿Cuál es el tercer objetivo de la checklist que creó Karen?

R: profit

Se identificó una checklist que creó Karen en el directorio /root/Desktop/Checklist.

```
Check List:

- Gain Bob's Trust
- Learn how to hack
- Profit
```

P7: ¿Cuántas veces se ejecutó Apache?

R: 0

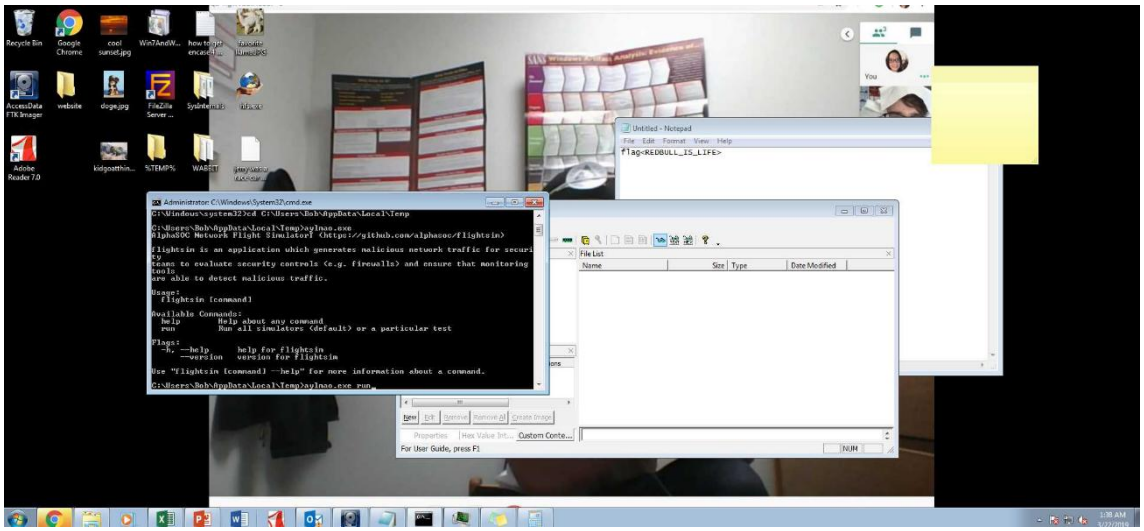
Para visualizar la información de Apache se investigó el archivo error.log ubicado en /var/apache2/, sin embargo, los archivos están vacíos (0 KB) entonces Apache no se ha ejecutado aún.

Name	Size	Type	Date Modif...
other_vhosts_acces...	0 (0 KB)	Regula...	9/11/2017 ...
error.log	0 (0 KB)	Regula...	9/11/2017 ...
access.log	0 (0 KB)	Regula...	9/11/2017 ...

P8: Esta máquina se usó para atacar a otra. ¿Qué archivo contiene la evidencia?

R: irZLAohL.jpeg

Se encontró una imagen en el directorio /root de nombre irZLAohL.jpeg. Esta imagen es una captura de pantalla donde se visualiza comandos ejecutados por el cmd con privilegios altos con el objetivo de iniciar un ejecutable desconocido aylmao.exe.



P9: Se cree que Karen se burlaba de un colega informático mediante un script bash en el directorio Documents. ¿Quién era el experto al que Karen se burlaba?

R: Young

En el archivo firstscript_fixed se puede visualizar un script bash donde Karen se burla de Young, probablemente un compañero de trabajo.

File List

Name	Size	Type	Date Modified
bob.txt	0 (0 KB)	Regular File	22/03/2019 04:11:22
didyouthinkwedmakeiteasy.jpg	1,865 (2 KB)	Regular File	22/03/2019 04:14:58
firstscript	46 (1 KB)	Regular File	22/03/2019 04:01:52
firstscript_fixed	216 (1 KB)	Regular File	22/03/2019 04:04:53
hellworld.sh	20 (1 KB)	Regular File	22/03/2019 04:00:22

```
echo "Showing you your current path"
pwd
echo "Show my default route"
ip route | grep --color default
echo "Show network connections w/ port 80"
netstat | grep --color 80
echo "Heck yeah! I can write bash too Young"
```

P10: Un usuario ejecutó el comando "su" para obtener acceso root varias veces a las 11:26. ¿Quién era el usuario?

R: postgres

Se investigaron los archivos de registro de autenticación y seguridad de Linux y se encontró que el usuario postgres ejecutó el comando “su” varias veces a las 11:26.

```
Mar 20 11:26:22 KarenHacker su[4060]: pam_unix(su:session): session closed for user postgres
Mar 20 11:26:22 KarenHacker su[4074]: Successful su for postgres by root
Mar 20 11:26:22 KarenHacker su[4074]: + ??? root:postgres
Mar 20 11:26:22 KarenHacker su[4074]: pam_unix(su:session): session opened for user postgres by (uid=0)
Mar 20 11:26:22 KarenHacker su[4074]: pam_systemd(su:session): Cannot create session: Already occupied by a session
Mar 20 11:26:22 KarenHacker su[4074]: pam_unix(su:session): session closed for user postgres
Mar 20 11:26:22 KarenHacker su[4081]: Successful su for postgres by root
Mar 20 11:26:22 KarenHacker su[4081]: + /dev/pts/0 root:postgres
Mar 20 11:26:22 KarenHacker su[4081]: pam_unix(su:session): session opened for user postgres by (uid=0)
Mar 20 11:26:22 KarenHacker su[4081]: pam_systemd(su:session): Cannot create session: Already occupied by a session
Mar 20 11:26:22 KarenHacker su[4081]: pam_unix(su:session): session closed for user postgres
Mar 20 11:26:22 KarenHacker su[4094]: Successful su for postgres by root
Mar 20 11:26:22 KarenHacker su[4094]: + /dev/pts/0 root:postgres
Mar 20 11:26:22 KarenHacker su[4094]: pam_unix(su:session): session opened for user postgres by (uid=0)
Mar 20 11:26:22 KarenHacker su[4094]: pam_systemd(su:session): Cannot create session: Already occupied by a session
Mar 20 11:26:22 KarenHacker su[4094]: pam_unix(su:session): session closed for user postgres
Mar 20 11:26:22 KarenHacker su[4101]: Successful su for postgres by root
Mar 20 11:26:22 KarenHacker su[4101]: + /dev/pts/0 root:postgres
Mar 20 11:26:22 KarenHacker su[4101]: pam_unix(su:session): session opened for user postgres by (uid=0)
Mar 20 11:26:22 KarenHacker su[4101]: pam_systemd(su:session): Cannot create session: Already occupied by a session
Mar 20 11:26:23 KarenHacker su[4101]: pam_unix(su:session): session closed for user postgres
Mar 20 11:26:23 KarenHacker su[4114]: Successful su for postgres by root
Mar 20 11:26:23 KarenHacker su[4114]: + /dev/pts/0 root:postgres
Mar 20 11:26:23 KarenHacker su[4114]: pam_unix(su:session): session opened for user postgres by (uid=0)
Mar 20 11:26:23 KarenHacker su[4114]: pam_systemd(su:session): Cannot create session: Already occupied by a session
Mar 20 11:26:23 KarenHacker su[4114]: pam_unix(su:session): session closed for user postgres
Mar 20 11:35:01 KarenHacker CRON[4363]: pam_unix(cron:session): session opened for user root by (uid=0)
```

P11: Según el historial de bash, ¿cuál es el directorio de trabajo actual?

R: /root/Documents/myfirsthack/

En el historial de bash se encontró que el directorio de trabajo actual que Karen ingresó fue /root/Documents/myfirsthack/.

```
sl
ls
cd ../Documents/myfirsthack/
netstat
echo bob.txt
touch bob.txt
echo "If you're still reading this file, scream cake."
echo "Seriously, we'll give you a hint to answer question if you scream cake."
```